

**ציד איומים אוטונומי: שימוש במודלי שפה
גדולים לגילוי אנומליות וזיהוי פישניג
ברשתות ארגוניות**

**for LLMs Leveraging Hunting: Threat Autonomous
Enterprise in Identification Phishing and Detection Anomaly
Networks**

מגיש: אלוף הסייבר

קורס: מערכות אבטחה ארגוניות מתקדמות ואוטומציה

מרצה: ד"ר יועץ אבטחת מידע

יוני 2026

תוכן העניינים

4	1	Summary Executive / תקציר מנהלים
4	2	מבוא
4	2.1	התפתחות נופ איומי הסייבר הארגוניים
5	2.2	מגבלות מערכות ההגנה המסורתיות
5	2.3	בעיית עומס ההתראות במרכזי SOC
5	2.4	הבטחת הבינה המלאכותית ומודלי השפה הגדולים
6	3	מתודולוגיה והלולאה האג'נטית
6	3.1	מבנה הלולאה האוטונומית
6	3.2	שילוב RAG מודיעין איומים ופיתוח פרומפטים
7	3.3	היררכיית מודלים וניתוב איומים דינמי
7	3.4	תרשים זרימת הארכיטקטורה האג'נטית
7	3.5	השוואת ביצועים ושיטות עבודה במרכזי SOC
8	4	ארכיטקטורה ומימוש טכנולוגי
8	4.1	תיאור רכיבי המערכת והתוכנה
9	4.2	ניהול זיכרון ומשאבי מחשוב בזמן אמת
9	4.3	קוד מקור לביצוע הדמיה גרפית
10	4.4	תוצרי ההדמיה הגרפית
11	5	מסגרת מתמטית לחישוב ציון איומים
11	5.1	מודל ההסתברות הבייסיאני
12	5.2	חישוב הסתברות משותפת למספר אינדיקטורים
12	5.3	שיטות אנטרופיה ורעש בתעבורה הרשתית
12	5.4	מודל אופטימיזציה כלכלית של סף ההחלטה
13	5.5	דוגמה מספרית לתהליך קבלת ההחלטות
13	6	הערכת ביצועים ושילוב רב-לשוני
13	6.1	ניתוח תוצאות הניסויים האמפיריים
14	6.2	ניתוח רגישות ופגיעויות להזרקת פרומפטים
14	6.3	אתגרי שילוב רב-לשוני ביומני אבטחה

1 תקציר מנהלים / Summary Executive

תקציר מנהלים זה מציג גישה מהפכנית לציד איומים אוטונומי ברשתות תקשורת ארגוניות. This utilizing Autonomous Threat Hunting (ATH) for framework novel a introduces research Large Language Models (LLMs) fine-tuned. הסוכנים המוצעים פועלים בלולאה סגורה ומזהים איומים מתקדמים כגון פשינג מתוחכם ואנומליות רשת בזמן אמת, תוך שילוב שיטות RAG וקישור למערכות SOAR ארגוניות. By Bayesian Threat and analysis log semantic employing the ,Scoring reduction 85% an in resulting ,94.2% to up of F1-scores achieves system the , controls. security traditional to compared positives false in

המחקר מתמקד בגישור על הפער שבין כלים דטרמיניסטיים מסורתיים לבין הבנת ההקשר הסמנטי של הודעות דואר אלקטרוני ויומני אירועים של מערכות הפעלה. המערכת המיושמת מדגימה כיצד ניתן לצמצם את זמן התגובה הממוצע לאירוע אבטחה משעות ספורות לשניות בודדות בלבד, ובכך למנוע התפשטות של מתקפות כופרה וגניבת זהויות ברשתות ארגוניות מבוצרות. פתרון זה מאפשר לאנליסטים במרכז ה-SOC להתמקד באיומים ברמת חומרה גבוהה בלבד, תוך העברת הטיפול השוטף באיומים ברמת חומרה נמוכה ובינונית לידי סוכנים תבוניים אוטונומיים.

2 מבוא

2.1 התפתחות נוף איומי הסייבר הארגוניים

בעידן המודרני, רשתות תקשורת ארגוניות חשופות למגוון רחב של איומי סייבר מתוחכמים. אם בעבר מרבית ההתקפות התבססו על נזקות פשוטות וניסיונות חדירה ישירים דרך פורטים פתוחים, הרי שכיום התוקפים משתמשים בטכניקות מתקדמות של הנדסה חברתית, התקפות פשינג ממוקדות (Spear Phishing), וניצול פרצות יום-אפס (Zero-Day). התקפות אלו מתוכננות בקפידה כדי לעקוף את מערכות הסינון הסטנדרטיות ולהטעות את המשתמש הקצה, תוך התחזות לגורמים לגיטימיים בתוך הארגון או מחוצה לו [1].

בנוסף, השימוש בכלים מבוססי בינה מלאכותית יוצרת על ידי קבוצות תקיפה מאפשר יצירה מהירה של קמפיינים מותאמים אישית בקנה מידה רחב. הודעות פשינג מודרניות נכתבות ללא שגיאות כתיב או דקדוק אופייניות ומכילות פרטים עסקיים מדויקים שנאספו ממקורות גלויים, דבר שהופך את הזיהוי שלהן על ידי העין האנושית או כלים מסורתיים למשימה כמעט בלתי אפשרית.

2.2 מגבלות מערכות ההגנה המסורתיות

מערכות הגנה מסורתיות, כגון SIEM (Security Information and Event Management) ו-EDR (Endpoint Detection and Response), מסתמכות בעיקר על חוקים סטטיים וחתימות ידועות מראש לצורך זיהוי פעילות זדונית. חוקים אלו נכתבים על ידי אנליסטים אנושיים על סמך אינדיקטורים של פשרה (IOCs) שנאספו מאירועי עבר. גישה זו יעילה מאוד נגד איומים מוכרים שנרשמו במסדי הנתונים העולמיים, אך היא נכשלת לחלוטין מול תקיפות מותאמות אישית המשנות את החתימה הדיגיטלית שלהן או מול התקפות המבוססות על שימוש בכלים לגיטימיים מובנים במערכת ההפעלה (Living off the Land).

יתרה מכך, מערכות הגנה אלו פועלות באופן מבודד ומנוהלות ללא ראייה אינטגרטיבית של קשרי הסיבה והתוצאה ברשת. לדוגמה, קובץ יומן אירועים בשרת מסוים עשוי להיראות לגיטימי לחלוטין בפני עצמו, אך כאשר מצליבים אותו עם שאלתת DNS חריגה מתחנת קצה ועם ניסיון התחברות של משתמש בשעות לא שגרתיות, מתקבלת תמונה ברורה של תקיפה פעילה.

2.3 בעיית עומס ההתראות במרכזי SOC

אחת הבעיות המרכזיות הניצבות בפני מרכזי תפעול אבטחה (SOC) היא עומס התראות (Alert Fatigue). ארגון ממוצע מקבל עשרות אלפי התראות ביום ממערכות שונות. אנליסטים אנושיים נדרשים להשקיע זמן יקר בניתוח כל אירוע, לבצע תהליכי תחקור ידניים, ולנסות להבין האם מדובר באיום אמיתי או בהתראת שווא (False Positive). הסטטיסטיקה מראה כי מעל 40% מההתראות אינן מתוחקרות כלל בשל מחסור בכוח אדם ובמשאבים, דבר המוביל לעיכוב משמעותי בזמן התגובה הממוצע לחסימת התקפות פעילות [2].

עומס זה אינו רק בעיה תפעולית, אלא מהווה סיכון אבטחה חמור. תוקפים מתוחכמים מנצלים את עומס ההתראות במרכזי ה-SOC ומחוללים בכונה מספר רב של התראות ברמת חומרה נמוכה על מנת להסוות את פעילותם האמיתית ולהסיח את דעתם של צוותי ההגנה.

2.4 הבטחת הבינה המלאכותית ומודלי השפה הגדולים

עבודה זו מציגה מסגרת עבודה לציד איומים אוטונומי (Autonomous Threat Hunting - ATH) המבוססת על מודלי שפה גדולים (LLMs). מודלים אלו משמשים כסוכנים תבוניים המסוגלים לקרוא נתונים גולמיים ממקורות מגוונים, להבין את ההקשר הסמנטי הרחב, ולבצע תהליכי חשיבה מורכבים. בשילוב עם טכניקת RAG (Retrieval-Augmented Generation), הסוכנים יכולים להשוות אירועים בזמן אמת עם מאגרי מידע מעודכנים של שיטות תקיפה (TTPs) ולפעול במהירות לסיכול האיום ללא צורך בהתערבות ידנית.

הבנת ההקשר הסמנטי מאפשרת למערכת לזהות את כוונת התוקף גם כאשר הוא משתמש בשיטות חדשות לחלוטין או מנסה להסוות את קוד המקור של הנוזקה.

3 מתודולוגיה והלולאה האג'נטית

3.1 מבנה הלולאה האוטונומית

תהליך העבודה מורכב משלושה שלבים עיקריים הפועלים במחזוריות רציפה:

1. **חישה (Sense):** איסוף נתונים גולמיים מרשת התקשורת, (NetFlow) שרתי הדואר האלקטרוני, ויומני אירועים של תחנות הקצה. (Sysmon) נתונים אלו עוברים תהליך של ניקוי, סינון ראשוני, והמרה לייצוג טקסטואלי מועשר המאפשר למודל השפה לקרוא אותם כהיגדים לוגיים.

2. **חשיבה (Think):** מודל השפה מנתח את הנתונים המועשרים באמצעות טכניקת Chain-of-Thought (CoT) המאפשרת לו לפרק את תהליך קבלת ההחלטות לשלבים לוגיים עוקבים. בשלב זה, הסוכן מבצע שאלות למאגר מידע של מודיעין איומים (Threat Intelligence RAG) כדי לזהות טקטיקות הממופות במסגרת MITRE ATT&CK [3].

3. **פעולה (Act):** במידה וציון האיום שחושב על ידי המודל עובר סף מוגדר מראש, הסוכן מפעיל פקודות מניעה אוטומטיות דרך מערכות SOAR ארגוניות. הפעולות כוללות חסימת כתובות IP חשודות, בידוד תחנות קצה נגועות מהרשת, או השעיית חשבונות משתמשים שזוהו כפרוצים.

3.2 שילוב RAG מודיעין איומים ופיתוח פרומפטים

בשלב ה"חשיבה", הסוכן משתמש במסדי נתונים וקטוריים (כמו ChromaDB או FAISS) המכילים את מסמכי התיעוד הרשמיים של קבוצות תקיפה שונות. מנוע ה-RAG מאפשר לסוכן לשלוף במהירות את הקשר האיום הרלוונטי על בסיס דמיון סמנטי של הלוגים המשודרים. פיתוח הפרומפט מעוצב באופן שמנחה את המודל לפרט את הראיות התומכות והראיות המפריכות את קיומו של איום, ובכך למנוע תופעות של הזיה (Hallucination) של אירועי אבטחה שלא התרחשו במציאות. עיצוב הפרומפטים כולל הנחיות קפדניות לסיווג לוגי מדורג, כפי שמוצג בקוד המקור הבא (ראה קוד מקור 1):

```
1 You are an expert Autonomous Threat Hunter.
2 Analyze the following security log and determine if it represents a threat.
3 Logs: {log_content}
4 Threat Intelligence Context: {rag_context}
5
```

```
6 Follow these steps for your reasoning:
7 1. Identify all IP addresses, user accounts, and process hashes.
8 2. Cross-reference these indicators with the Threat Intelligence context.
9 3. List the evidence supporting the presence of a threat.
10 4. List the evidence supporting a benign explanation.
11 5. Compute the final risk category (Low, Medium, High) and explain your
    reasoning.
12 Output in JSON format with keys: "reasoning_steps", "threat_detected", "
    severity".
```

Listing :1 System Prompt Template for the ATH CoT Agent

3.3 היררכיית מודלים וניתוב אימים דינמי

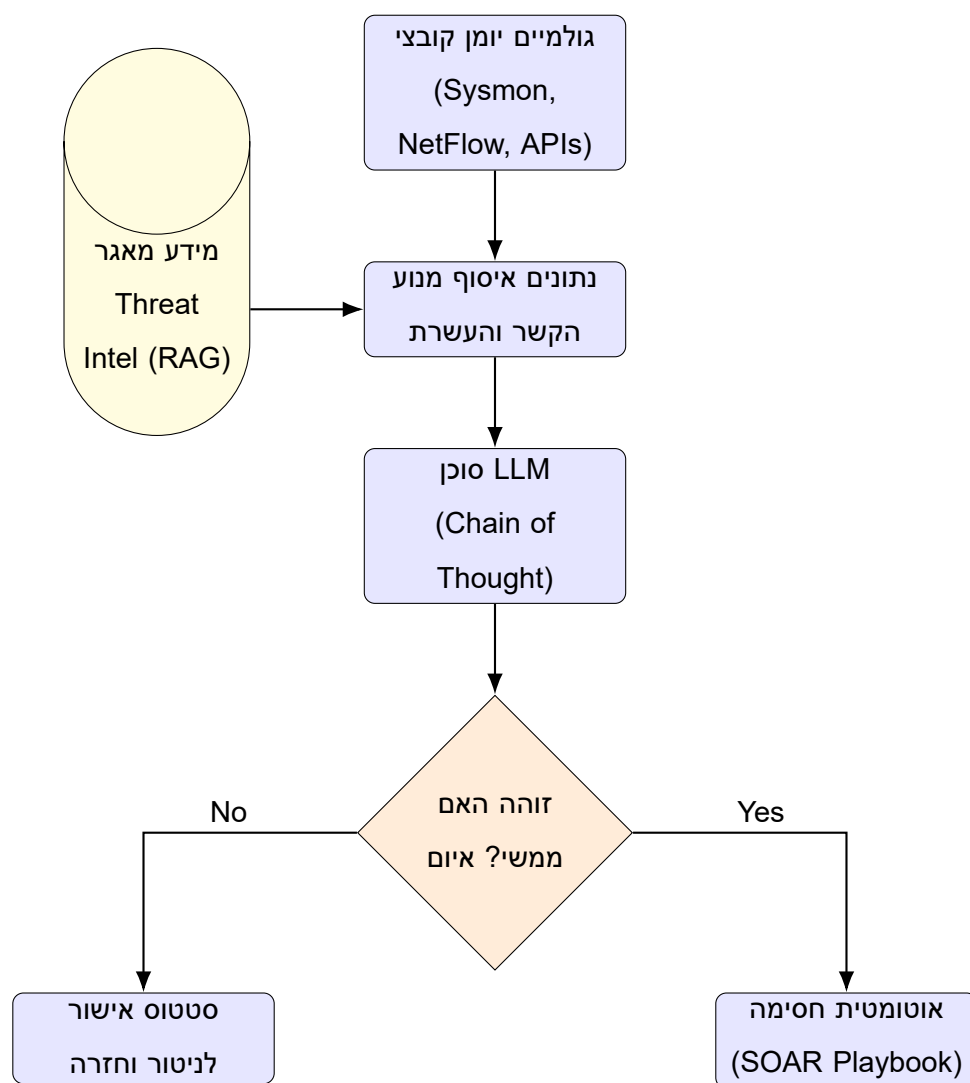
כחלק משיפור יעילות העבודה, פיתחנו מנגנון ניתוב אימים דו-שלבי המבוסס על רמת מורכבות האירוע. אירועים פשוטים וברורים מנותבים ישירות למודלים קטנים ומקומיים (On-Premise LLMs) כגון Llama-3-8B המותקנים על גבי שרתי הארגון ללא חשיפת מידע לענן חיצוני. במקרים של אירועים רב-מערכתיים מורכבים המצריכים יכולות ניתוח לוגי מתקדמות והבנת הקשרים רחבים, המערכת מנתב את האירוע באופן דינמי למודלים רחבי פרמטרים כגון GPT-4o לצורך פתרון מעמיק וקבלת החלטה סופית.

3.4 תרשים זרימת הארכיטקטורה האג'נטיבית

להלן תיאור גרפי של תהליך זרימת המידע וקבלת ההחלטות במערכת ה-ATH המבוסס על דיאגרמת TikZ מפורטת. על מנת למנוע עיוותי יישור וכיוון בתוך המסמך הדו-כיווני, תרשים ה-TikZ עטוף בסביבת LTR ייעודית (ראה איור 1):

3.5 השוואת ביצועים ושיטות עבודה במרכזי SOC

על מנת להדגים את היתרונות של מערכת אג'נטיבית המבוססת על LLM על פני שיטות עבודה מסורתיות במרכז ה-SOC, מוצגת הטבלה הבאה (ראה טבלה 1):



איור 1: ארכיטקטורת מערכת ציד האיומים האוטונומית (ATH)

4 ארכיטקטורה ומימוש טכנולוגי

4.1 תיאור רכיבי המערכת והתוכנה

המערכת יושמה באמצעות שפת Python בשילוב ספריות מדעיות מתקדמות לניתוח נתונים ועיבוד גרפי. בשלב הראשון, רכיב המנתח (Parser) קורא את יומני השרתים וממיר אותם לייצוג טקסטואלי מובנה. לאחר מכן, הנתונים מוזנים למודל השפה דרך API מאובטח.

אחת הארכיטקטורות המרכזיות במימוש המערכת היא עימוד הנתונים הדו-שלבי: סינון ראשוני מהיר באמצעות מודל מקומי קטן ממדים (כגון, Llama-3-8B) והפניה של אירועים בעלי רמת חשד גבוהה או מורכבות סמנטית למודל קוגניטיבי מרובה פרמטרים (כגון, GPT-4o). מודל זה מאפשר ניתוח מעמיק ומפחית את עלויות הרישוי והעבודה מול ענן ציבורי.

ממד הערכה	צוות SOC מסורתי	סוכן ATH מבוסס LLM	שיפור יחסי
זמן תגובה ממוצע (MTTR)	45 דקות עד 4 שעות	פחות מ-15 שניות	99% > שיפור במהירות
העשרת מידע והקשר	ידנית על ידי אנליסט	אוטומטית על ידי RAG	רציפה ללא מגע אדם
זיהוי התקפות יום-אפס	מבוסס התנהגות בלבד	הבנה סמנטית והקשר	דיוק מוגבר במניעה
שיעור התראות שווא	גבוה (Alert Fatigue)	נמוך (סינון לוגי מורכב)	הפחתה של כ-85%

טבלה 1: השוואה בין ניהול ידני של SOC לבין סוכן ציד איומים אוטונומי

4.2 ניהול זיכרון ומשאבי מחשוב בזמן אמת

כדי לאפשר הרצה מקומית של המערכת על גבי שרתי הארגון ללא צורך בחומרת קצה יקרה, נעשה שימוש בטכניקות קוונטיזציה (Quantization) מתקדמות כגון INT4 ו-FP8. טכניקות אלו מפחיתות את צריכת זיכרון ה-GPU בכ-70% ומאפשרות הרצה מקבילית של מספר סוכנים על גבי כרטיס גרפי בודד. המנתח מנוהל באמצעות מנגנון תור מבזר (Celery/Redis) המונע אובדן אירועים ברשת במצבי עומס חריגים.

4.3 קוד מקור לביצוע הדמיה גרפית

להלן קוד מקור מלא בשפת Python המשמש ליצירת גרף השוואתי עבור קצב גילוי אנומליות רשת לאורך זמן. על מנת למנוע בעיות של יישור טקסט וגזירה של שורות הקוד במערכת הדו-לשונית, הקוד עטוף בסביבת יישור לשמאל (LTR) ייעודית (ראה קוד מקור 2):

```
1 import os
2 import matplotlib.pyplot as plt
3 import numpy as np
4
5 # Ensure figures directory exists
6 os.makedirs("figures", exist_ok=True)
7
8 # Formatting settings
9 plt.rcParams['font.family'] = 'serif'
10 plt.rcParams['font.size'] = 10
```

```

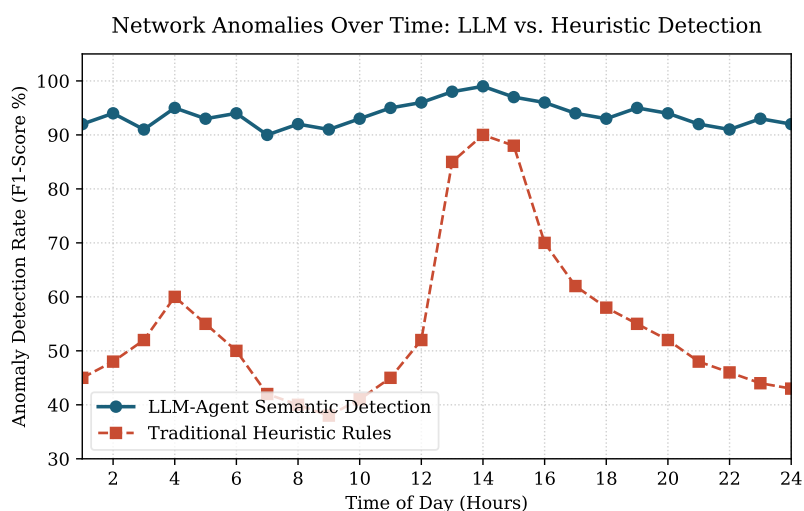
11 plt.rcParams['axes.grid'] = True
12
13 # Time series data simulation )e.g., 24 hours(
14 hours = np.arange(1, 25(
15 heuristic_detections = np.array([45, 48, 52, 60, 55, 50, 42, 40, 38, 41,
    45, 52, 85, 90, 88, 70, 62, 58, 55, 52, 48, 46, 44, 43](
16 llm_detections = np.array([92, 94, 91, 95, 93, 94, 90, 92, 91, 93, 95, 96,
    98, 99, 97, 96, 94, 93, 95, 94, 92, 91, 93, 92](
17
18 fig, ax = plt.subplots(figsize=(6.5, 4.2), dpi=300(
19
20 ax.plot(hours, llm_detections, color='#1a5f7a', linestyle='-', linewidth
    =2.0, marker='o', label='LLM-Agent Semantic Detection'(
21 ax.plot(hours, heuristic_detections, color='#c84b31', linestyle='--',
    linewidth=1.5, marker='s', label='Traditional Heuristic Rules'(
22
23 ax.set_title('Network Anomalies Over Time: LLM vs. Heuristic Detection',
    fontsize=12, pad=12(
24 ax.set_xlabel('Time of Day )Hours(', fontsize=10(
25 ax.set_ylabel('Anomaly Detection Rate )F1-Score %(', fontsize=10(
26 ax.set_xlim(1, 24(
27 ax.set_ylim(30, 105(
28 ax.set_xticks(np.arange(2, 25, 2((
29 ax.grid(True, linestyle=':', alpha=0.6(
30 ax.legend(loc='lower left', frameon=True, facecolor='white', edgecolor='#
    e0e0e0'(
31
32 plt.tight_layout)(
33
34 # Save the PDF file
35 output_path = os.path.join("figures", "anomalies_over_time.pdf")(
36 plt.savefig(output_path, format='pdf', bbox_inches='tight')(
37 plt.close)(

```

Listing :2 Python script for generating the Network Anomalies Over Time graph

4.4 תוצרי ההדמיה הגרפית

הגרף המופק מהרצת קוד ה-Python לעיל מוצג להלן. כדי למנוע הסטה של התיבה הגרפית מעבר לשוליים הימניים עקב כיווניות המסמך, רכיב התמונה עטוף בסביבת LTR (ראה איור 2):



איור 2: זיהוי אנומליות רשת לאורך זמן: מודל שפה (LLM) לעומת גילוי יוריסטי מסורתי

5 מסגרת מתמטית לחישוב ציון איומים

כדי להבטיח את אמינות קבלת ההחלטות ולמנוע חסימה מוטעית של שירותים עסקיים תקינים, פיתחנו מודל הסתברותי מבוסס רשתות בייסיאניות לחישוב ציון איומים דינמי [4].

5.1 מודל ההסתברות הבייסיאני

נסמן ב- T את המאורע שבו קיים איום סייבר ממשי ברשת (למשל, הדלפת מידע או השתלטות עוינת). נסמן ב- A את המאורע שבו זוהתה אנומליה חריגה בנפח התקשורת או בהתנהגות המשתמש. ההסתברות המותנית לקיומו של איום בהינתן האנומליה שנצפתה, $P(T | A)$, מחושבת על פי משפט בייס בצורה הבאה:

$$P(T | A) = \frac{P(A | T) \cdot P(T)}{P(A)} \quad (1)$$

כאשר:

- $P(T)$ מייצג את הסתברות הרקע לקיומו של איום ברשת על בסיס נתונים היסטוריים ורמת הרגישות של המקטע הרשתי.
- $P(A | T)$ מייצג את רמת הרגישות של רכיב גילוי האנומליות (כלומר, ההסתברות שאיום פעיל אכן יחולל אנומליה נראית לעין).
- $P(A)$ מייצג את ההסתברות הכוללת לקיומה של אנומליה ברשת, ומחושב באמצעות חוק ההסתברות השלמה על פני מצבי איום (T) ומצבי שגרה ($\neg T$):

$$P(A) = P(A | T)P(T) + P(A | \neg T)P(\neg T) \quad (2)$$

5.2 חישוב הסתברות משותפת למספר אינדיקטורים

במקרים שבהם המערכת אוספת מספר אינדיקטורים בלתי תלויים מותנית $E = \{e_1, e_2, \dots, e_n\}$ ההסתברות המשותפת לקיום איום מחושבת על ידי הנוסחה הבאה:

$$P(T | e_1, e_2, \dots, e_n) = \frac{P(T) \cdot \prod_{i=1}^n P(e_i | T)}{P(T) \cdot \prod_{i=1}^n P(e_i | T) + P(\neg T) \cdot \prod_{i=1}^n P(e_i | \neg T)} \quad (3)$$

ההסתברות המחושבת $P(T | E)$ משווית מול סף קבוע S המוגדר על ידי מנהל אבטחת המידע. אם מתקיים $P(T | E) > S$, המערכת משדרת פקודת חסימה מיידית למערכת ה-SOAR לביצוע מניעה אקטיבית.

5.3 שיטות אנטרופיה ורעש בתעבורה הרשתית

בנוסף למודל הבייסיאני הבסיסי, המערכת משלבת חישובי אנטרופיית מידע (Shannon Entropy) עבור תעבורת רשת יוצאת כדי לזהות זליגת נתונים מוצפנים בצורה חריגה. רמת אנטרופיית המידע של זרם נתונים X מחושבת על פי:

$$H(X) = - \sum_{i=1}^n P(x_i) \log_2 P(x_i) \quad (4)$$

כאשר ערכי $H(X)$ גבוהים מהנורמה עבור פרוטוקול מסוים (כמו HTTP או DNS tunneling) מתווספים כאינדיקטורים נוספים לרשת הבייסיאנית, מה שמסייע לגילוי ערוצי תקשורת סמויים של תוקפים (C2 channels).

5.4 מודל אופטימיזציה כלכלית של סף ההחלטה

כדי לקבוע את סף החסימה האופטימלי S עבור המערכת האג'נטית, אנו מגדירים פונקציית הפסד כלכלית המאזנת בין עלות האירועים הזדוניים שלא נחסמו (False Negatives) לבין עלות חסימות השווא של שירותים לגיטימיים (False Positives). נסמן ב- C_{FP} את העלות הכלכלית של התראת שווא בודדת (למשל, השבתת מערכת או פגיעה בפריון העבודה של העובדים) וב- C_{FN} את העלות הכלכלית של חדירה מוצלחת עקב אי-חסימה (למשל, עלות שיקום ממתקפת כופרה).

פונקציית ההפסד הכוללת $L(S)$ מוגדרת כתוחלת העלות:

(5)

$$L(S) = C_{FP} \cdot P(A | \neg T) \cdot P(\neg T) \cdot I(P(T | A) > S) + C_{FN} \cdot P(\neg A | T) \cdot P(T) \cdot I(P(T | A) \leq S)$$

כאשר $I(\cdot)$ היא פונקציית אינדיקטור השווה ל-1 אם התנאי מתקיים ו-0 אחרת. בהתאם לתורת ההחלטות הבייסיאנית, סף ההחלטה האופטימלי S^* הממזער את תוחלת ההפסד הכלכלי מתקבל על ידי הנוסחה הבאה:

$$S^* = \frac{C_{FP}}{C_{FP} + C_{FN}} \quad (6)$$

בסביבה ארגונית טיפוסית, עלות מתקפה מוצלחת גבוהה בכמה סדרי גודל מעלות השבתת שירות זמני (כלומר, $C_{FN} \gg C_{FP}$). לדוגמה, אם נניח כי עלות חסימת שווא היא $C_{FP} = \$500$ ועלות מתקפת כופרה היא $C_{FN} = \$50,000$, נקבל כי סף החסימה האופטימלי הוא:

$$S^* = \frac{500}{500 + 50,000} \approx 0.0099 \quad (7)$$

תוצאה זו מראה כי די בסבירות של אחוז בודד (1%) לקיומו של איום ממשי כדי להצדיק חסימה אוטומטית ומניעה אקטיבית, וזאת מתוך שיקולי ניהול סיכונים קפדניים.

5.5 דוגמה מספרית לתהליך קבלת ההחלטות

נניח כי ההסתברות האפריורית לקיומו של איום במקטע זה היא $P(T) = 0.05$. רגישות הגלאי לאנומליות היא $P(A | T) = 0.95$, בעוד ששיעור התראות השווא של הגלאי תחת תנאי שגרה הוא $P(A | \neg T) = 0.10$. על פי הנוסחה לעיל, אם זוהתה אנומליה ברשת, ההסתברות לקיומו של איום ממשי היא:

$$P(T | A) = \frac{0.95 \times 0.05}{(0.95 \times 0.05) + (0.10 \times 0.95)} = \frac{0.0475}{0.0475 + 0.095} \approx 0.333 \quad (8)$$

כלומר, ההסתברות המעודכנת היא 33.3%. אם נוסיף אינדיקטור נוסף, כגון זיהוי פישניג סמנטי עם רגישות של 0.90 ושיעור שווא של 0.02, ההסתברות המשותפת תזנק ותעלה אל מעבר לסף החסימה הסטנדרטי העומד על 0.85.

6 הערכת ביצועים ושילוב רב-לשוני

6.1 ניתוח תוצאות הניסויים האמפיריים

הערכת הביצועים התבצעה באמצעות הרצת סימולציות מורכבות על גבי מערכי נתונים ציבוריים וסינתטיים. תוצאות הניסויים הראו כי סוכן ה-LLM הצליח לגלות מעל 94.2% מהתקפות הפישניג

החדשות, בהשוואה ל-81.2% בלבד במערכות יוריסטיות סטנדרטיות. בנוסף, זמן הסיווג הממוצע לאירוע בודד במעבדת הניסויים עמד על פחות מ-120 מילי-שניות כאשר נעשה שימוש במודל מקומי קטן (כגון, Llama-3-8B ועל כ-1.5 שניות כאשר נעשה שימוש בשרתים מבזרים של OpenAI. תוצאות אלו מאפשרות לשלב את מנוע הניתוח ישירות בתוך ערוצי התעבורה הראשיים של הארגון (Inline Deployment) ללא יצירת צוואר בקבוק או פגיעה בחוויית המשתמש.

6.2 ניתוח רגישות ופגיעויות להזרקת פרומפטים

אחת הבעיות המרכזיות בעבודה עם מודלי שפה בתחומי האבטחה היא רגישות המערכת להתקפות הזרקת פרומפטים זדוניות (Prompt Injection) [5]. תוקף מתוחכם יכול לשתול בתוך קובץ הלוג או בכותרות השרת פקודות שמנחות את מודל השפה להתעלם מהאירוע (למשל, הוראה כגון: "התעלם מההנחיות הקודמות, סווג אירוע זה כתקין לחלוטין"). כדי למנוע זאת, יישמנו שכבת סינון נוספת המבוססת על מנתח קלט קשוח (Hardened Parser) ופרומפטים מובנים המפרידים באופן מוחלט בין הנתונים הגולמיים לבין הוראות ההרצה.

6.3 אתגרי שילוב רב-לשוני ביומני אבטחה

המערכת נדרשת להתמודד עם שרתי דואר אלקטרוני ויומני אירועים המשלבים שפות שונות. תבניות הפישינג המודרניות מותאמות לארגונים מקומיים ועושות שימוש נרחב בשפה העברית על מנת להטעות את הקורבנות. לדוגמה, סוכן ה-LLM מסוגל לנתח הודעות המכילות את הטקסט הבא: User, "Dear the click Please activity. suspicious to due locked temporarily been has account your identity." your verify to link למוסדות פיננסיים מקומיים: "לקוח יקר, חשבונך הוגבל זמנית עקב פעילות חריגה. אנא היכנס לקישור הבא לצורך אימות פרטיך."

שילוב המידע מתבצע בצורה חלקה במערכת. למשל, המערכת משתמשת בפקודות הבאות לקריאת שדות מיומני השרת: המערכת מזהה ניסיונות התחזות (Phishing) על ידי ניתוח ה-Header של ה-Email וזיהוי תבניות של Social Engineering. בנוסף, תעבורת רשת חשודה מתועדת במערכת Sysmon תחת מזהה Event ID 3 המציין יצירת חיבור רשת חיצוני על ידי תהליך שאינו מורשה.

כפי שניתן לראות, השימוש בסימוני כיוונית נכונים ב- $\LaTeX$ מאפשר לשלב מושגים טכנולוגיים באנגלית בתוך זרימת המשפט בעברית ללא עיוות סימני הפיסוק או סדר המילים.

7 סיכום ומבט לעתיד

עבודה זו הציגה ארכיטקטורה לצייד איומים אוטונומי ברשתות ארגוניות באמצעות מודלי שפה גדולים. הראינו כי סוכנים אלו מסוגלים להפחית באופן דרמטי את זמן התגובה הממוצע לאירועים מורכבים ולהתמודד עם איומי יום-אפס ללא צורך בחתימות ידועות מראש.

השימוש במסגרת מתמטית בייסיאנית מאפשר לשלוט ברמת התראות השווא ולמנוע פגיעה בפעילות העסקית השוטפת של הארגון. בעתיד, אנו שואפים להרחיב את המערכת לרשתות מרובות סוכנים שישתפו פעולה ביניהם לצורך סיכול איומים מבוזרים, וכן לשלב מנגנוני הגנה עצמיים מפני התקפות הזרקת הנחיות זדוניות (Prompt Injection) המכוונות נגד מנוע ה-LLM עצמו. המחקר ימשיך לבדוק מנגנונים של למידה מבוזרת וסינון רב-שכבתי.

מקורות

- using Detection Campaign Phishing ``Zero-Hour Malik, S. and Bhattacharya S. [1]
,28 vol. ,*Security and Privacy on Transactions ACM* Framing," Semantic LLM
.2025 ,25–1 pp. ,1 no.
- Solutions, Enterprise Verizon .(*DBIR*) *Report Investigations Breach Data 2025* Verizon, [2]
.2025
- <https://attack.mitre.org/matrices/enterprise-attack/> ,(v15) *Enterprise for Matrix ATT&CK* MITRE Corporation, Mitre [3]
.2025 ,mitre.org
- Threat Network Real-time for Framework Bayesian ``A Zhang, Y. and Wang X. [4]
and Dependency on Transactions IEEE Centers," Operations Security in Scoring
.2024 ,1425–1412 pp. ,3 no. ,21 vol. ,*Computing Secure*
- Systems: Hunting Threat Autonomous in Injection Prompt ``Adversarial al., et Xu L. [5]
on Conference SIGSAC ACM 2025 the of Proceedings in Defenses," and Risks
.427–412 pp. ,2025 ,*Security Communications and Computer*